

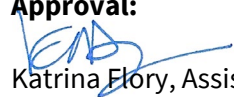


DAS Policy

System Maintenance

No:
2100-18

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to establish **System Maintenance** requirements to ensure Ohio Department of Administrative Systems (**DAS**)-**Managed Information Systems, IT Equipment**, as well as any associated state **Data**, is properly protected during maintenance. In the context of this policy, maintenance does not include application updates performed under release management processes.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations," family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable. The requirements of the NIST SP 800-53 Maintenance (MA) control family are addressed in this policy.

II. Scope

The scope of this policy includes DAS-Managed Information Systems and IT Equipment that is authorized to conduct state business.

This policy also applies to DAS **Data Owners**, system or **Service Owners**, and extends to managed service providers.

III. Policy

System owners shall establish System Maintenance procedures to ensure DAS-Managed Information Systems and IT Equipment is properly maintained.

- A. **Controlled Maintenance (MA-2)**: System owners shall perform maintenance activities in accordance with manufacturer or vendor specifications. Maintenance activities shall be scheduled, documented, and reviewed following established change management practices in accordance with DAS Policy 2100-09, "Configuration Management."
1. All maintenance activities shall be approved and monitored, whether performed on-site or remotely, and whether the DAS-Managed Information System or IT Equipment is serviced on-site or removed to another location.
 2. Removal of DAS-Managed Information Systems or IT Equipment from organizational facilities for off-site maintenance or repairs shall be explicitly approved by the **Information System** owner and/or Data Owner.
 3. System and user Data shall be backed up, if deemed necessary by the Data Owner and system/Service Owner, in accordance with DAS Policy 2100-16, "Contingency Planning," prior to commencing maintenance activities.
 4. IT Equipment shall be **Sanitized** in accordance with State of Ohio Administrative Policy IT-05, "Disposal, Servicing and Transfer of IT Equipment," to remove all information from associated media prior to removal from organizational facilities for off-site maintenance or repairs.
 5. All potentially impacted security controls shall be checked to verify that the controls are still functioning properly following maintenance or repair actions.
 6. System owners shall document maintenance activities, in accordance with DAS approved change management procedures.
 7. Automated mechanisms shall be used to schedule, conduct, and document maintenance and repairs, wherever possible.
 8. Up-to-date, accurate, and complete records of all maintenance and repair actions requested, scheduled, in-process, and completed shall be maintained by system owners, and available for inspection.
- B. **Maintenance Tools (MA-3)**: Maintenance tools shall be approved, controlled, and monitored.
1. Tools carried by maintenance personnel into facilities housing DAS-Managed Information Systems or IT Equipment approved to conduct state business shall be inspected by the system owner for improper or unauthorized modifications.
 2. Media containing diagnostic and test programs shall be checked for **Malicious Code** before the media are used in an Information System.
- C. **Nonlocal Maintenance (MA-4)**: Nonlocal Maintenance shall be conducted as follows:
1. All Nonlocal Maintenance and diagnostic activities shall be approved and monitored by the system owner.

2. Procedures for the establishment and use of Nonlocal Maintenance, diagnostic connections, and tools shall be documented in the security plan for the Information System.
 3. Multifactor authentication is required for Nonlocal Maintenance and diagnostic sessions in accordance with DAS Policy 2100-02, "Remote Access," and DAS 2100-14, "Multifactor Authentication."
 4. Records of Nonlocal Maintenance and diagnostic activities shall be maintained.
 5. Sessions shall be terminated and network connections shall be dropped when Nonlocal Maintenance is completed.
- D. **Maintenance Personnel (MA-5):** System owners shall establish processes for maintenance personnel authorization and maintain a list of authorized maintenance organizations or personnel.
1. Non-escorted personnel performing maintenance on DAS-Managed Information Systems or IT Equipment shall be assigned required access authorizations.
 2. Personnel with required access authorizations and technical competence to supervise the maintenance activities of personnel, who do not possess the required access authorizations, shall be assigned to oversee maintenance activities.
- E. **Timely Maintenance (MA-6):** Maintenance support and/or critical spare parts shall be available and/or on-hand to ensure **Service Level Agreements** are met in the event of an Information System or IT Equipment failure.
- F. **Exception Process:** To request an exception to one or more of the requirements outlined in this policy, please complete an IT Security Exception Request form.
1. The form is located within the IT Enterprise Services Portal under the "Services & Products" category.
 2. If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

IV. Definitions

- A. DAS-Managed Information System. Information Systems that reside in facilities or infrastructure managed by DAS OIT personnel. Primary responsibility for managing these systems may be assigned to DAS OIT personnel or other outside entities.
- B. Data. Coded representation of quantities, objects and actions. The word, "Data," is often used interchangeably with the word, "information," in common usage and in this policy.

- C. Data Owner. The Data Owner is responsible for the identification and classification of information, in consultation with Legal Counsel, and shall address the assignment of Data classification labels, Data compilation, Data classification coordination, Data classification compliance and Data access. The role of a Data Owner and his/her associated responsibilities are addressed in detail within Ohio Administrative Policy IT-13, "Data Classification."
- D. Information System. A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.¹
- E. IT Equipment. IT Equipment includes devices that are capable of persistent data storage, for example computer hardware; telecommunications equipment; digital devices such as digital copiers and facsimile machines; mobile computing devices; operational technology (e.g., building and manufacturing controls); or Internet of Things (IoT) devices. It also includes media that is capable of storing information such as: tokens, USB sticks, memory cards, hard drives, DVDs, CDs, tapes, microfilm, paper records, etc.
- F. Malicious Code. Software or firmware intended to perform an unauthorized process that will have an adverse impact on the confidentiality, integrity, or availability of an Information System. Some examples include a virus, worm, Trojan horse, or other code-based entity that infects a host. Spyware and some forms of adware are also examples of Malicious Code.²
- G. Nonlocal Maintenance. Maintenance activities conducted by individuals communicating through a network, either an external network (e.g., the Internet) or an internal network.³
- H. Sanitize. A general term referring to the actions taken to render Data written on media unrecoverable by both ordinary and, for some forms of sanitization, extraordinary means.⁴
- I. Service Level Agreement. Defines the services to be delivered, technical support and other parameters that, by contract, a business or supporting activity is required to deliver. The Service Level Agreement should describe performance measures as well as penalties for failure to perform in accordance with the Service Level Agreement.
- J. Service Owner. A Service Owner is responsible for the delivery (design, performance, and integration), continual improvement and management of assigned IT services.
- K. System Maintenance. For the purposes of this policy, System Maintenance includes all types of maintenance to any system component (including applications), conducted by any local or nonlocal entity (e.g., in-contract, warranty, in-house, software maintenance agreement). System Maintenance also includes those components not directly associated with information processing and/or Data/information retention such as scanners, copiers, and

¹ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² *Ibid.*

³ *Ibid.*

⁴ *Ibid.*

printers.⁵ It does not include application updates performed under release management processes.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-05 Disposal, Servicing and Transfer of IT Equipment	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-02 Remote Access	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-09 Configuration Management	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-14 Multifactor Authentication	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-16 Contingency Planning	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology

⁵ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/21/2018	Original Policy.
06/10/2020	Updated the policy template.
08/02/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.